

Awareness and Training	3.6.3
Business Priority	Relevant quote from casefile
impeccable protection of customer privacy	Greg: I thought it was VERY clear what our business priorities here at Rigel are: - exceptional patient care - innovative software development for delivering that exceptional patient care - impeccable protection of customer privacy How did this fall between the cracks? Willa Herzog CEO
exceptional patient care	Greg: I thought it was VERY clear what our business priorities here at Rigel are: - exceptional patient care - innovative software development for delivering that exceptional patient care - impeccable protection of customer privacy How did this fall between the cracks? Willa Herzog CEO Rigel Cybernetics Institute
innovative software development for delivering that exceptional patient care	Greg: I thought it was VERY clear what our business priorities here at Rigel are: - exceptional patient care - innovative software development for delivering that exceptional patient care - impeccable protection of customer privacy How did this fall between the cracks? Willa Herzog CEO Rigel Cybernetics Institute

3.6.3 CSF Phase	3.6.3 CSF Phase Sub-category	3.6.3 Problem name	3.6.3 Description	3.6.3 Relevant quotes from casefile	3.6.3 Relevance to RCI's priorities	3.6.4 Root cause	3.6.5 Problem ID
4 Respond	Respond - IRPs	IRP not kept updated	IRP was 2 years out of date	"Apparently Sean updated it two years ago. (yikes)" [Email 2.8]		Weak governance and poor update policies	4:1
5 Recover	Recover - Backup & restoration	No recent backups	Patient data backups were outdated (8 months old)	"Good news: there's a backup! Bad news: the backup is eight months old." [Email 3.1]		Lack of established backup management procedures	5:1
3 Detect	Detect - Continuous monitoring (SIEM)	SIEM poorly configured	SIEM alerts were ineffective due to improper tuning	"Kinda wishing we'd made tuning the SIEM a higher priority" [Email 2.4]		Inadequate prioritization of security system configurations	3:1
1 Identify	Identify - Asset inventory	Asset not recorded in CMDB	Server EHR-14 was not documented in the CMDB	"Our CMDB doesn't even list EHR-14" [Email 2.3]		Poor asset management practices	1:1
4 Respond	Respond - RCA	Data breach incident	Sensitive patient data was exfiltrated	"The attackers appear to be selling the data they stole..." [Email 6.3]		Outbound data filters and DLP were not in place	4:2
1 Identify	Identify - Risk assessments	Outdated security audit	Last security audit performed months ago	"Our last authorized audit was in August" [Email 6.2]		Insufficient regular risk assessment and compliance checks	1:2
4 Respond	Respond - Incident remediation processes	Poor Incident Response Preparedness	IRP contains placeholders and missing critical sections	"Our IRP only has placeholders for the section on where to report breaches" [Email 6.5]		IRP not practiced or tested	4:3
2 Protect	Protect - Security awareness	Phishing and malware infiltration	Workstation infected via malicious email attachment	"The attacker probably sent her some bogus patient records" [Email 6.2]		Poor cybersecurity awareness training programs	2:1
3 Detect	Detect - IDS/IPS	Improper network monitoring	ARP spoofing and unauthorized traffic unnoticed	"We see evidence of ARP spoofing to intercept LAN traffic" [Email 6.2]		Weak network monitoring and intrusion detection practices (Switches don't check for ARP-spoof traffic)	3:2
3 Detect	Detect - IDS/IPS	Unexamined Snort logs	Logs from a key workstation had not been analyzed	"...digging into the (until now, unexamined) Snort logs..." [Email 6.2]		Incomplete log analysis and delayed response	3:3
3 Detect	Detect - Continuous monitoring (SIEM)	Lateral movement between systems	Communication between compromised endpoints	"We see consistent traffic between Records-013 and EHR-14" [Email 6.2]		No segmentation or lateral movement detection	3:4
3 Detect	Detect - Continuous monitoring (SIEM)	Misconfigured Snort rules	Alerts were not parsed correctly, rendering them useless	"Turns out a bunch weren't being parsed correctly, so the alerts we'd set up didn't fire." [Email 6.2]		Misconfigured or unmaintained IDS detection rules	3:5
3 Detect	Detect - Continuous monitoring (SIEM)	C2 traffic not detected	C2 traffic from infected workstation went unnoticed	"...workstation showed consistent C2 traffic..." [Email 6.2]		No alert watches for unusual outbound connections	3:6
3 Detect	Detect - Continuous monitoring (SIEM)	Alert rules not properly tested	Detection logic not validated which led to alert failure	"Turns out a bunch weren't being parsed correctly..." [Email 6.2]		No testing procedures for rule configuration	3:7
3 Detect	Detect - IDS/IPS	Undocumented detection bypass	Scanning activity from Records-013 overlooked for weeks	"Several bouts of scanning activity...going back to the end of September (!)" [Email 6.2]		Lack of baselining or anomaly alerting	3:8
3 Detect	Detect - Continuous monitoring (SIEM)	Suspicious egress traffic not escalated	Snort alert indicated egress, but not properly escalated	Snort alert for unusual egress traffic" [Email 6.2]		Poor incident triage and escalation process	3:9
4 Respond	Respond - IRPs	Forensics capability reactive	Forensics only initiated post-compromise	"We've pulled the workstation for forensic examination" [Email 6.2]		No proactive endpoint visibility tooling	4:4
2 Protect	Protect - Security awareness	Email attachment threat vector	Malicious file attachment led to infection	"...sent her some bogus patient records and that's how her workstation got infected" [Email 6.2]		Inadequate phishing detection simulation training and Mail gateway allows executable attachments through	2:2
2 Protect	Protect - Data (in transit)	LAN lacks ARP spoofing protections	ARP spoofing was used to intercept LAN traffic, indicating weak segmentation or LAN defenses	We see evidence of ARP spoofing to intercept LAN traffic" [Email 6.2]		Inadequate LAN segmentation and lack of ARP protection mechanisms	2:3
3 Detect	Detect - IDS/IPS	Unauthorized scanning activity	Recon scanning from Records-013 went undetected for weeks	"...several bouts of scanning activity..." [Email 6.2]		No host-based monitoring or lateral movement controls	3:10
2 Protect	Protect - Patch management	Meterpreter implant undetected	C2 implant active without detection	"...associated with a Meterpreter implant." [Email 6.2]		Weak endpoint protection or antivirus capability	2:4
2 Protect	Protect - Patch management	Weak email filtering/sandboxing	Phishing email bypassed gateway filtering	"...some bogus patient records..." [Email 6.2]		No sandboxing or file behavior analysis at gateway	2:5
2 Protect	Protect - Data (at rest)	Flat network allowed lateral spread	Infected systems communicated without segmentation	"...traffic between Records-013 and EHR-14..." [Email 6.2]		Lack of VLANs or internal network segmentation	2:6
1 Identify	Identify - Risk assessments	Incomplete audit scope	Critical systems were not reviewed in audits	"...unexamined Snort logs..." [Email 6.2]		Audit scope did not include all high-value endpoints	1:3
3 Detect	Detect - IDS/IPS	No User Behavior Analytics (UBA)	Traffic patterns not baselined or flagged as abnormal	"...consistent traffic between..." [Email 6.2]		Lack of User Behavior Analytics or anomaly detection system	3:11

3.6.4	3.6.5	3.6.6
Root cause	Problem ID	Solution(s)
IR plan & audits overdue	1:2, 1:3, 4:1, 4:3	Launch a security-governance calendar with quarterly IR-plan reviews and an annual tabletop that rehearses outage of the EHR-14 cluster.
Poor asset management practices	1:1	Run an automatic scan each day that adds every new server to the inventory list and shows who owns it.
Phishing training & filters weak	2:1, 2:2, 2:5	Train staffs on a short phishing quiz and simulation every month and set the mail system to open risky attachments in a safe sandbox first.
Flat LAN / no VLAN, ARP guard	2:3, 2:6, 3:2, 3:4	Split the network into separate zones (reception PCs, patient-record servers, labs) and turn on the switch setting that blocks ARP spoofing.
Endpoints lack EDR visibility	3:10, 2:4, 4:4	Replace old antivirus with a modern endpoint-security tool that can spot unusual behaviour and stop it or can remote respond when needed.
SIEM / IDS rules never QA-tested	3:1, 3:5, 3:7	Test every new alert rule in a small lab first to be sure it fires before moving it to the live system.
Logs stored but not reviewed / no baseline	3:3, 3:6, 3:8, 3:11	Add a behaviour-analytics add-on to the SIEM so it warns when traffic or user actions look abnormal.
No alert-to-incident mitigation/ hand off process	3:9	Create a rule: when a "critical" alert fires, PagerDuty, texts the on-call team and opens a communication platform for the whole response crew.
Outbound data filters and DLP were not in place	4:2	Set firewall / web-proxy rules to scan outgoing files for patient data and block large transfers that are not
Backups old and untested	5:1	Take nightly backups, keep an off-site copy that can't be changed, and do a test restore regularly.

[illegible]